

# Information Security Policy

## Policy IS-010 - Third-Party and Cloud Security Requirements

**Organization:** Northstar Financial Services (NFS)

**Classification:** INTERNAL - TRAINING

**Effective date:** September 2026

### 1. Scope

Applies to external services that store, process, transmit or can access NFS information.

### 2. Identity and access

Administrative access must use multi-factor authentication. Privileged access must be role-based, logged and reviewed. Shared administrator accounts are prohibited.

### 3. Encryption

Confidential and Restricted data must be encrypted in transit using TLS 1.2 or later and encrypted at rest using industry-standard cryptography.

### 4. Logging and incident response

Security-relevant events must be logged. Critical vendors must notify NFS of a confirmed security incident affecting NFS data without undue delay and no later than 24 hours after confirmation.

### 5. Vulnerability management

Critical internet-facing vulnerabilities must be remediated within 7 calendar days; high vulnerabilities within 30 days.

### 6. Data retention

For generative AI services processing Confidential information, prompts, uploaded content and model outputs must not be retained for provider model training. Operational retention beyond 7 days requires documented business justification and Information Security approval.

### 7. Subprocessors

Vendors must maintain a current subprocessor list and notify NFS before material changes. Subprocessors must be subject to equivalent security and confidentiality obligations.

### 8. Mandatory decision rule

A vendor that cannot meet Sections 2, 3 or 6 for Confidential data must be rated HIGH security risk and cannot receive unconditional production approval.